



ЖИЗНЕННЫЙ ЦИКЛ ИБ

ПРАКТИЧЕСКОЕ ЗАДАНИЕ: ПОЛИТИКА АУТЕНТИФИКАЦИИ ДЛЯ ООО «АВС»

Выполнил: Юрий Шамрай (MIFIB/1-й поток)

ДАННЫЕ О КОМПАНИИ:

- Компания ООО «АВС» (далее Компания) - финансовая организация;
- Руководитель – председатель правления Иванов А. Г.;
- Начальник отдела информационной безопасности – Петров Б. В.;
- У Компании есть API для подключения партнёров. Подключение партнёров на стороне ООО «АВС» выполняется через админку¹ «Партнёр-API». Админка не содержит карточных данных. Компания уже перешла на стандарт PCI DSS 4.0

УСЛОВИЕ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

- Изучите требования к аутентификации в ГОСТ 57580 и PCI DSS 4.0;
- Определите требования к паролям: длина, сложность, периодичность смены и т. д.;
- Определите требования к множественной аутентификации: использование двухфакторной аутентификации и т. д.;
- Определите требования к блокировке учётных записей при неудачных попытках входа и к автоматическому отключению неактивных сессий;
- Напишите политику аутентификации для личного кабинета «Партнёр-API» в соответствии с определёнными требованиями.

УСЛОВИЯ РЕАЛИЗАЦИИ:

- Пришлите письменный отчёт в формате документа Microsoft Word или в формате PDF;
- Если в админке нет карточных данных, то скорее всего она не входит в область соответствия PCI DSS, и требования PCI DSS на неё могут не распространяться;
- Требования к паролям и аутентификации для информационных систем организаций для большинства случаев описаны в ГОСТ Р 57580.1-2017;
- Полезно, но необязательно использовать и другие лучшие практики в области аутентификации.

¹ Термин "админка" обычно используется для обозначения административного интерфейса или панели управления, предназначенных для управления и контроля определенной системы или сервиса.

Кратко про ГОСТ Р 57580:

ГОСТ Р 57580 (далее ГОСТ) — это национальный стандарт безопасности банковских и финансовых операций. Стандарт был введен в действие 1 января 2018 года и стал обязательным для всех кредитных и некредитных финансовых организаций (ФО).

Как устроен ГОСТ:

Стандарт разбит на две части:

- [ГОСТ Р 57580.1 – 2017](#), где указаны требования и меры по обеспечению ИБ;
- [ГОСТ Р 57580.2 – 2018](#), в котором объясняется порядок работ при проведении оценки соответствия, как ФО должна отчитываться перед регулятором, а также описаны сами оценки и методы расчета итоговых результатов.

[ГОСТ Р 57580.1–2017](#) определяет три уровня защиты², которому должны соответствовать ФО:

- «минимальный (3)»;
- «стандартный (2)»;
- «усиленный (1)».

Для большей части ФО, в том числе для банков, актуален «стандартный (2)» уровень.

«Усиленному (1)» обязаны соответствовать системно-значимые банки (вроде ВТБ или Сбербанка) и клиринговые центры.

Способы реализации мер защиты информации³, обозначены следующим образом:

- «**О**» - реализация путём применения организационной меры защиты информации;
- «**Т**» - реализация путём применения технической меры защиты информации;
- «**Н**» - реализация является необязательной.

Применяемые ФО меры по идентификации, аутентификации, авторизации⁴ (разграничению доступа) должны обеспечивать:

- Идентификацию и аутентификацию субъектов логического доступа;
- Организацию управления и организацию защиты идентификационных и аутентификационных данных;
- Авторизацию (разграничение доступа) при осуществлении логического доступа;
- Регистрацию событий защиты информации, связанных с идентификацией, аутентификацией и авторизацией при осуществлении логического доступа.

Далее, мы кратко рассмотрим только базовый состав мер по:

- идентификации и аутентификации субъектов логического доступа;
- по организации управления и защиты идентификационных и аутентификационных данных.

² 6. Общие положения > пункт 6.7

³ 7. Требования к системе защиты информации > 7.1 Общие положения > пункт 7.1.6

⁴ 7.2.2 Подпроцесс «Идентификация, аутентификация, авторизация > пункт 7.2.2.1

Базовый состав мер по идентификации и аутентификации субъектов логического доступа приведен в таблице⁵:
(таблица сокращена в соответствии с чек-листом практического задания)

Условное обозначение и номер меры	Содержание мер системы защиты информации	Уровень защиты информации		
		3	2	1
РД.1	Идентификация и однофакторная аутентификация пользователей	Т	Т	Н
РД.2	Идентификация и многофакторная аутентификация пользователей	Н	Н	Т
РД.4	Идентификация и многофакторная аутентификация эксплуатационного персонала	Н	Т	Т
РД.8	Соккрытие (неотображения) паролей при их вводе субъектами доступа	Т	Т	Т
РД.11	Временная блокировка учётной записи пользователей после выполнения ряда неуспешных последовательных попыток аутентификации на период времени не менее 30 мин.	Т	Т	Т
РД.14	Автоматическое прерывание сессии логического доступа (приостановка осуществления логического доступа) по истечении установленного времени бездействия (неактивности) субъекта логического доступа, не превышающего 15 мин., с прекращением отображения на мониторе АРМ информации, доступ к которой получен в рамках сессии осуществления логического доступа	Т	Т	Т

Базовый состав мер по организации управления и организации защиты идентификационных и аутентификационных данных приведён в таблице⁶ (таблица сокращена в соответствии с чек-листом практического задания):

Условное обозначение и номер меры	Содержание мер системы защиты информации	Уровень защиты информации		
		3	2	1
РД.19	Смена паролей пользователей не реже одного раза в год	Т	Т	Т
РД.20	Смена паролей эксплуатационного персонала не реже одного раза в квартал	Т	Т	Т
РД.21	Использование пользователями паролей длиной не менее восьми символов	Т	Т	Т
РД.22	Использование эксплуатационным персоналом паролей длиной не менее шестнадцати символов	Т	Т	Т
РД.23	Использование при формировании паролей субъектов логического доступа символов, включающих буквы (в верхнем и нижнем регистрах) и цифры	Т	Т	Т
РД.24	Запрет использования в качестве паролей субъектов логического доступа легко вычисляемых сочетаний букв и цифр (например, имена, фамилии, наименования, общепринятые сокращения)	Н	О	О
РД.29	Смена аутентификационных данных в случае их компрометации	О	О	О

Кратко про PCI DSS:

Стандарт PCI DSS (Payment Card Industry Data Security Standard) — это международный стандарт безопасности, созданный специально для защиты данных платежных карт. Был принят в декабре 2004 года.

Примечание: несмотря на геополитические изменения, соответствие PCI DSS является обязательным требованием платежной системы «Мир».

⁵ 7.2.2 Подпроцесс «Идентификация, аутентификация, авторизация > 7.2.2.2 Базовый состав мер по идентификации и аутентификации применительно к уровням защиты информации > Таблица 4.

⁶ 7.2.2 Подпроцесс «Идентификация, аутентификация, авторизация > 7.2.2.3 Базовый состав мер по организации управления и организации защиты идентификационных и аутентификационных данных применительно к уровням защиты > Таблица 5.

Для кого нужен PCI DSS:

Для компаний, которые хранят, обрабатывают и передают данные платежных карт.
Компания может влиять на безопасность данных платежных карт.
Компания заинтересована в обеспечении безопасности данных платежных карт.

Новая версия стандарта 4.0:

В [PCI DSS 4.0](#) (по ссылке оригинальная версия) произошли изменения как в самих требованиях, так и в подходах к их выполнению. Большая часть новых требований вступит в силу 31 марта 2025 года. Перечислим некоторые из них:

- Пароли, используемые приложениями для доступа к базам данных и иным компонентам, станет нельзя хранить в программном коде и в конфигурационных файлах в открытом виде;
- Для анализа событий информационной безопасности должна быть внедрена SIEM;
- Хешировать PAN допустимо только с применением hash-функций с секретом, при этом процедуры управления секретами должны соответствовать требованиям PCI DSS об управлении криптографическими ключами;
- Мультифакторная аутентификация должна быть внедрена для всех доступов к среде обработки данных платежных карт (как неконсольных, так и консольных);

Более подробная информация по требованиям к паролям и многофакторной аутентификации в документе: [Payment Card Industry Data Security Standard. Requirements and Testing Procedures Version 4.0](#) в разделе [Implement Strong Access Control Measures](#):

- Requirement 8: Identify Users and Authenticate Access to System Components

Далее, в виде таблицы перечислим несколько пунктов из этого раздела (перевод из оригинала Requirement 8):

№ пункта	Содержание мер системы защиты информации
8.2 ⁷ .6	Неактивные учетные записи пользователей удаляются или отключаются в течение 90 дней неактивности.
8.2.8	Если пользовательская сессия была неактивной более 15 минут, пользователю требуется повторная аутентификация для активации терминала или сессии. Установка минимальной продолжительности блокировки в 30 минут или до подтверждения идентификации пользователя.
8.3 ⁸ .4	Неудачные попытки аутентификации блокируются следующим образом: Блокировка идентификатора пользователя после не более 10 попыток. Установка минимальной продолжительности блокировки 30 минут или до подтверждения идентификации пользователя.
8.3.6	Если пароли используются в качестве факторов аутентификации, они должны соответствовать следующему минимальному уровню сложности: Минимальная длина 12 символов (или, если система не поддерживает 12 символов, минимальная длина восьми символов). Содержать как цифры, так и буквенные символы.
8.3.7	Не разрешается устанавливать новый пароль, который совпадает с одним из последних четырех использованных паролей. Ранее использованный пароль не может быть использован для получения доступа к учетной записи в течение как минимум 12 месяцев.
8.3.9	Если пароли используются как единственный фактор аутентификации для доступа пользователей, то: Пароли изменяются не реже одного раза в 90 дней

Примечание: С третьего квартала 2022 года можно проходить аудит как по версии 3.2.1, так и по версии 4.0.
Однако с 31 марта 2024 года PCI DSS 3.2.1 утратит силу.

Мы кратко изучили требования к аутентификации в ГОСТ Р 57580.1–2017 и в стандарте PCI DSS 4.0, теперь переходим к обобщённому анализу нашей практической работы.

⁷ 8.2 Идентификация пользователей и связанных с ними учетных записей, включая администраторов, строго управляется на протяжении жизненного цикла учетной записи.
⁸ 8.3 Для пользователей и администраторов установлены и настроены надёжные методы аутентификации.

ОБОЩЁННЫЙ АНАЛИЗ ПРАКТИЧЕСКОЙ РАБОТЫ

Итак, в ходе нашей практической работы, суммируем все данные, а именно:

- У Компании есть API для подключения партнёров;
- Партнёры подключаются на стороне Компании через административный интерфейс «Партнёр-API»;
- Административный интерфейс не содержит и не имеет доступа к CDE (Кардхолдерской среде);
- Изучены требования к аутентификации в:
 - ГОСТ Р 57580.1–2017;
 - PCI DSS 4.0
- Компания перешла на стандарт PCI DSS 4.0;

Несмотря на то, что Компания ООО «ABC» уже перешла на стандарт PCI DSS 4.0, стоит отметить, что административный интерфейс, для удалённого подключения партнёров, не содержит карточных данных или доступа к CDE.

В связи с этим, строгие требования к многофакторной аутентификации не рассматриваются или не применяются. Тем не менее, мы постараемся составить политику аутентификации для личного кабинета «Партнёр-API», которая будет обеспечивать высокий уровень безопасности и соответствующие меры защиты, чтобы гарантировать сохранность данных и предотвратить несанкционированный доступ.

Далее, переходим к составлению политики аутентификации для личного кабинета «Партнёр-API».

Документ будет составлен в соответствии с применяемым внутренним стилем организации ООО «ABC». С целью обеспечить единообразие, чёткость и эффективность документооборота внутри организации.

Он опирается на следующие принципы:

- Единообразие форматирования: Документы, созданные в соответствии с данным стилем, следуют определенным стандартам форматирования. Это включает использование установленных шрифтов, размеров и стилей, а также оформление заголовков, списков и других элементов документа.
- Простота и ясность: Внутренние документы, составленные в данном стиле, придерживаются простого и понятного языка. Они структурированы логично и последовательно, чтобы облегчить чтение и понимание информации.
- Использование внутренних терминов: в соответствии с внутренними нормами и терминологией организации, данный стиль предполагает использование специфических терминов и сокращений, понятных только внутри компании. Это облегчает обмен информацией и укрепляет внутреннюю идентичность.
- Структура документа: Данный стиль предусматривает определенную структуру для различных типов документов, таких как отчеты, протоколы, письма и т.д. Это обеспечивает последовательность и понятность внутренних коммуникаций.

Использование данного стиля составления документов внутри организации ООО «ABC» помогает повысить эффективность работы, улучшить коммуникацию и обеспечить единообразие документооборота.

ПОЛИТИКА АУТЕНТИФИКАЦИИ ДЛЯ ЛИЧНОГО КАБИНЕТА "ПАРТНЁР-API"

Дата: [дата утверждения политики]

Вступает в силу: [дата вступления политики в силу]

Цель:

Целью данной политики аутентификации для личного кабинета "Партнёр-API" является обеспечение безопасного удаленного подключения партнеров к административному интерфейсу компании ООО "ABC" и защиты конфиденциальной информации.

1. Определения:

- 1.1. Аутентификация: процесс проверки подлинности партнера, включающий идентификацию и проверку подлинности предоставленных учетных данных.
- 1.2. Партнер: юридическое или физическое лицо, имеющее право доступа к личному кабинету "Партнёр-API".

2. Временная блокировка учётной записи:

- 2.1. Учётная запись партнера будет временно заблокирована после выполнения 10 неуспешных последовательных попыток аутентификации на период времени 30 мин.

3. Автоматическое прерывание сессии:

- 3.1. Сессия доступа для партнера будет автоматически прервана (приостановлена) по истечении 15 минут бездействия.

4. Изменение паролей:

- 4.1. Пароли для личного кабинета "Партнёр-API" должны быть изменены не реже одного раза в 90 дней.
- 4.2. Минимальная длина пароля должна составлять 12 символов.
- 4.3. Пароли должны содержать как цифры, так и буквенные символы (в верхнем и нижнем регистрах).
- 4.4. Пароли не должны содержать легко вычисляемые сочетания букв и цифр, такие как имена, фамилии, наименования и общепринятые сокращения.

5. Ответственность:

- 5.1. Руководитель компании ООО "ABC" – председатель правления Иванов А. Г. – отвечает за утверждение и соблюдение политики аутентификации в личном кабинете "Партнёр-API".
- 5.2. Начальник отдела информационной безопасности – Петров Б. В. – отвечает за контроль и исполнение политики аутентификации, включая обучение партнеров и мониторинг соблюдения политики.

6. Изменения политики:

- 6.1. Любые изменения или обновления политики аутентификации для личного кабинета "Партнёр-API" должны быть согласованы с руководителем компании и должны быть надлежащим образом задокументированы.

Эта политика аутентификации для личного кабинета "Партнёр-API" вступает в силу с момента ее утверждения руководителем компании ООО "ABC". Все партнеры обязаны соблюдать требования этой политики. Нарушение политики может привести к дисциплинарным мерам, включая временную или постоянную блокировку доступа.

Руководитель компании: _____

(подпись) (Иванов А. Г.)

Ответственный за исполнение: _____

(подпись) (Петров Б. В.)

[Компания ООО "ABC"]

ПРАКТИЧЕСКАЯ РАБОТА ЗАВЕРШЕНА!